Push Comes To Shove: exploring the attack surface of SCCM Client Push Accounts

trimarcsecurity.com/hub-post/push-comes-to-shove-exploring-the-attack-surface-of-sccm-client-push-accounts

Brandon Colley July 1, 2022

Updated: Dec 13, 2024

Editors Note: Part 2 of this series is now published! Head over after you've finished reading Part 1.

Introduction

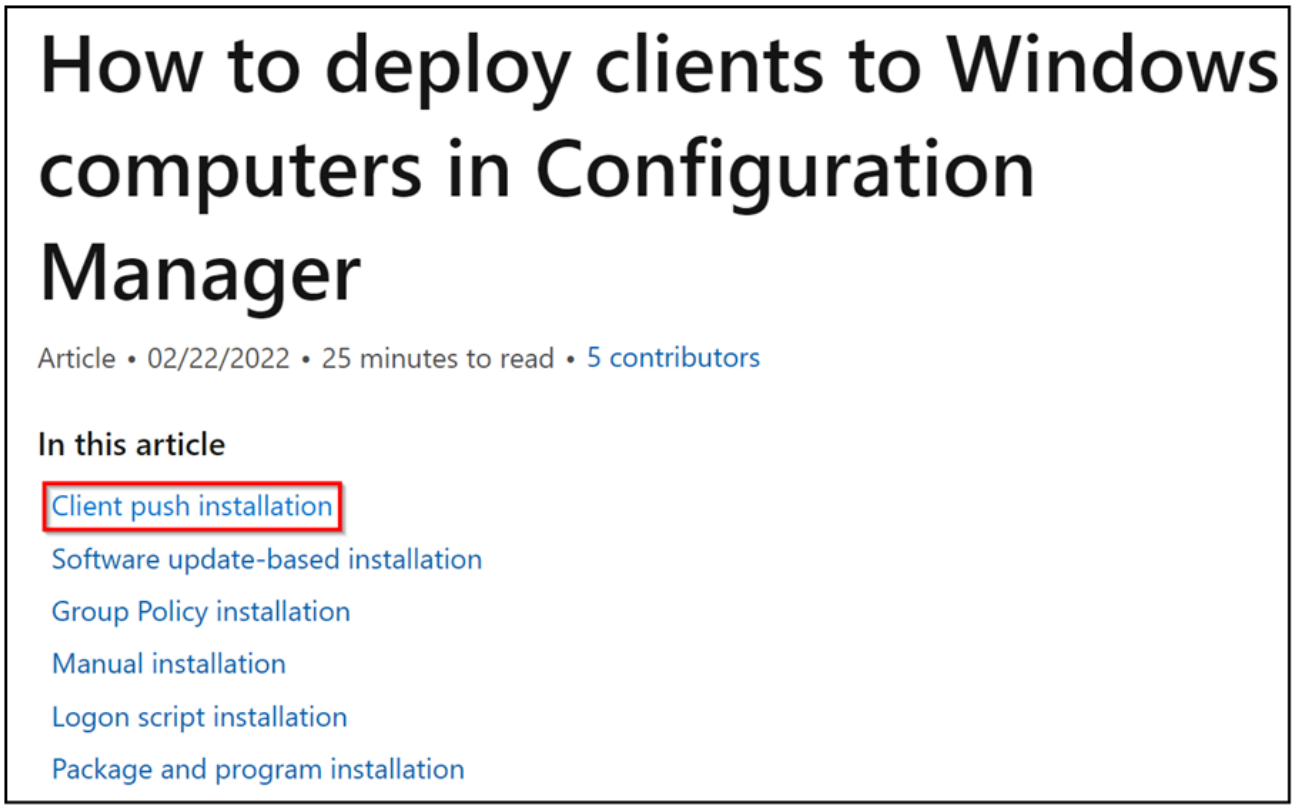
Did you know that Microsoft System Center Configuration Manager (SCCM) has been around for 28 years? Currently known as Microsoft Endpoint Configuration Manager (MECM), SCCM was first released in 1994 as Systems Management Server (SMS). Do you know what else happened in 1994? No, I wasn't born that year, but Justin Bieber was. China was connected to the Internet, and Jeff Bezos founded Amazon.

This isn't a story about 1994; it's a story about today. While you might not remember where you were when you found out Richard Nixon died (1994) you will remember when you learned how grossly vulnerable SCCM is. When push comes to shove, an attacker can fully compromise Active Directory (AD) in multiple ways.

This is the first article in a series that explores vulnerabilities associated with the SCCM push account. This article introduces the problems associated with how the client push accounts authenticate against endpoints.

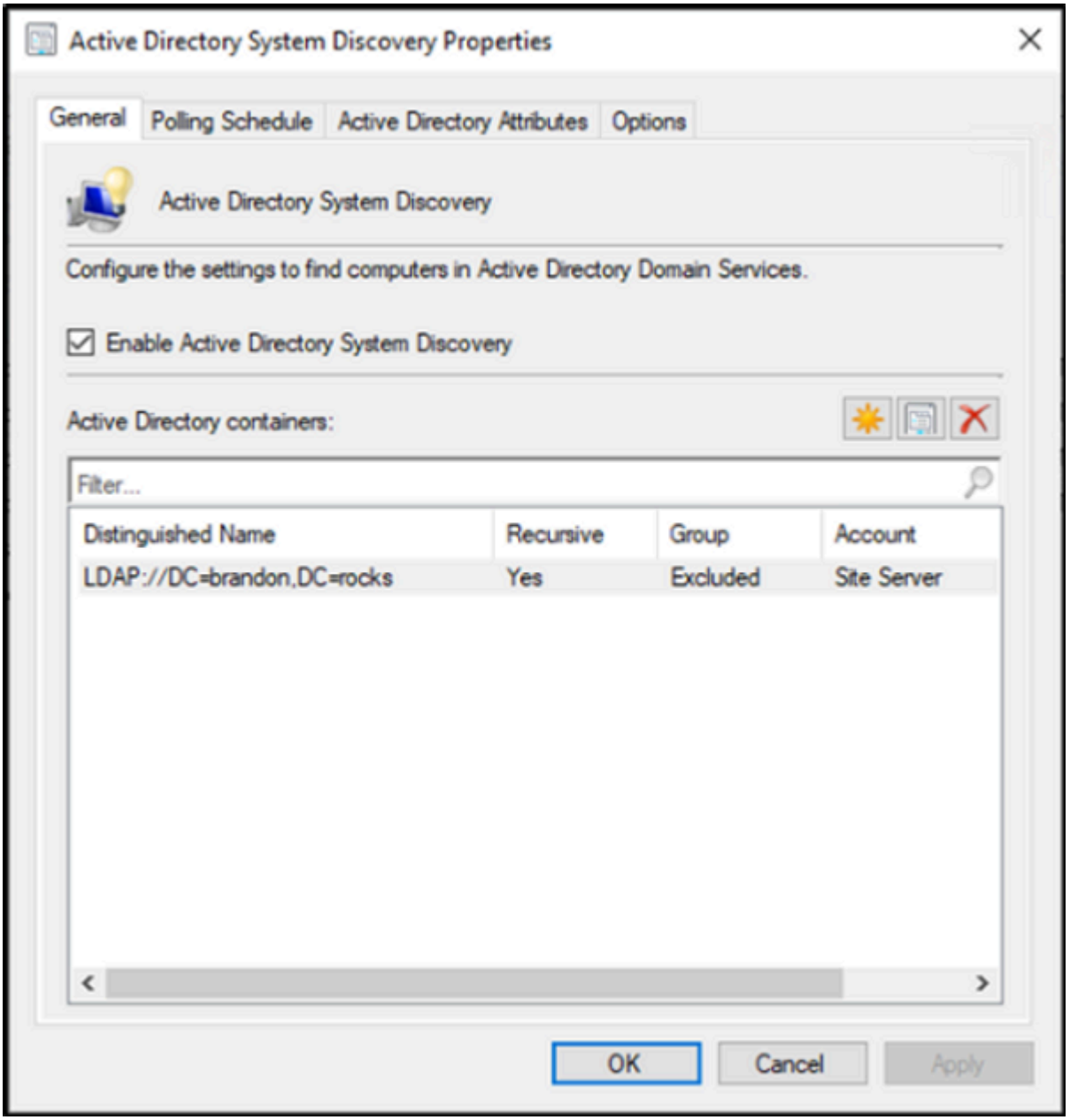
Client Push Installation

SCCM is a systems management product used by many companies to manage endpoints. It's a client-server application so one of the first steps when configuring SCCM is to deploy the client to computers. Microsoft provides multiple methods for deploying the client, but perhaps the most popular method is "client push installation". This method has been around for years and is listed at the top of Microsoft's documentation.

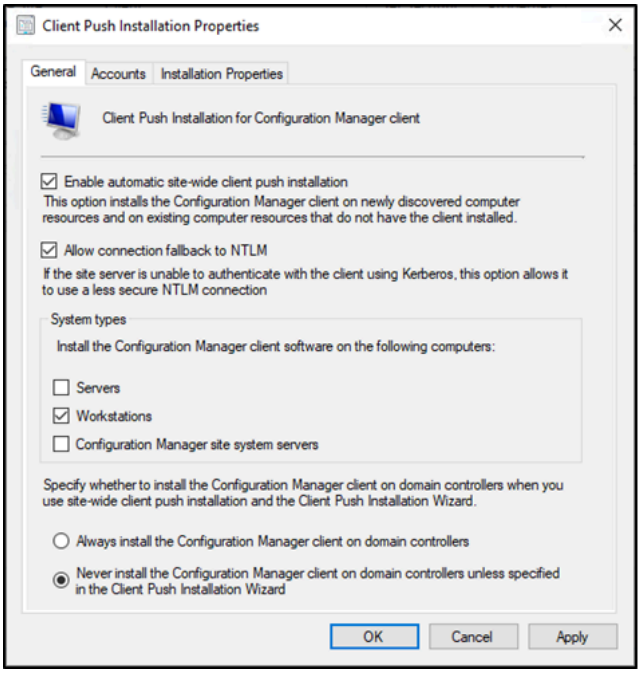


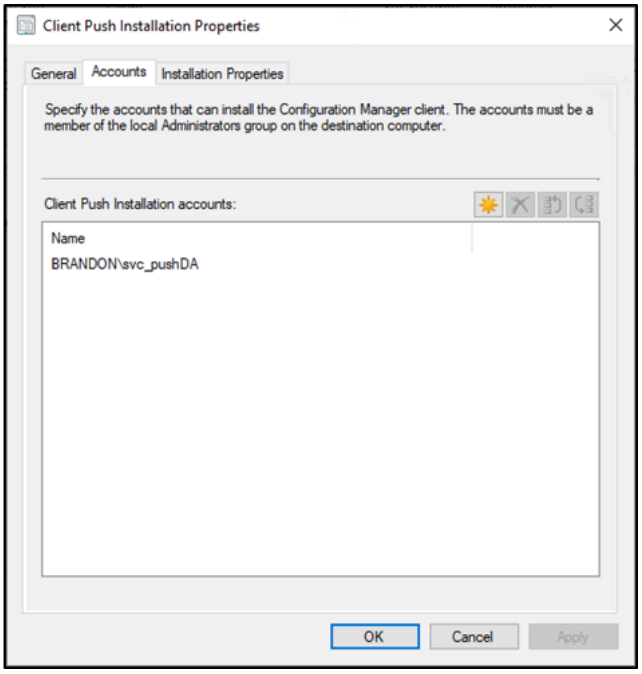
This is an attractive option, not only because it saves the administrator a few spins of the scroll wheel, but because it offers a lot of automation and integration with Active Directory (AD) and can automatically push clients to new devices.

Configuring Active Directory System Discovery in SCCM creates this integration with AD, allowing it to dynamically discover new computers in AD.



Once a device is discovered by SCCM, the client push installation uses its configured push account to deploy the client to the device.





Microsoft Recommendations

Awkwardly, Microsoft recommends against the use of the client push installation for security reasons. In their “Security and Privacy for Clients” document, it is stated that:

> Of all the client installation methods, client push installation is the least secure because of the many dependencies it has. These dependencies include local administrative permissions, the `Admin$` share, and firewall exceptions. The number and type of these dependencies increase your attack surface.

They go on to recommend that if you must use the client push installation, secure the client push installation account.

Limit Push Account Privileges

> ### If you must use client push installation, secure the client push installation account
>
> The client push installation account must be a member of the local **Administrators** group on each computer that installs the Configuration Manager client. Never add the client push installation account to the **Domain Admins** group. Instead, create a global group, and then add that global group to the local **Administrators** group on your clients. Create a group policy object to add a **Restricted Group** setting to add the client push installation account to the local **Administrators** group.

> For greater security, create multiple client push installation accounts, each with administrative access to a limited number of computers. If one account is compromised, only the client computers to which that account has access are compromised.

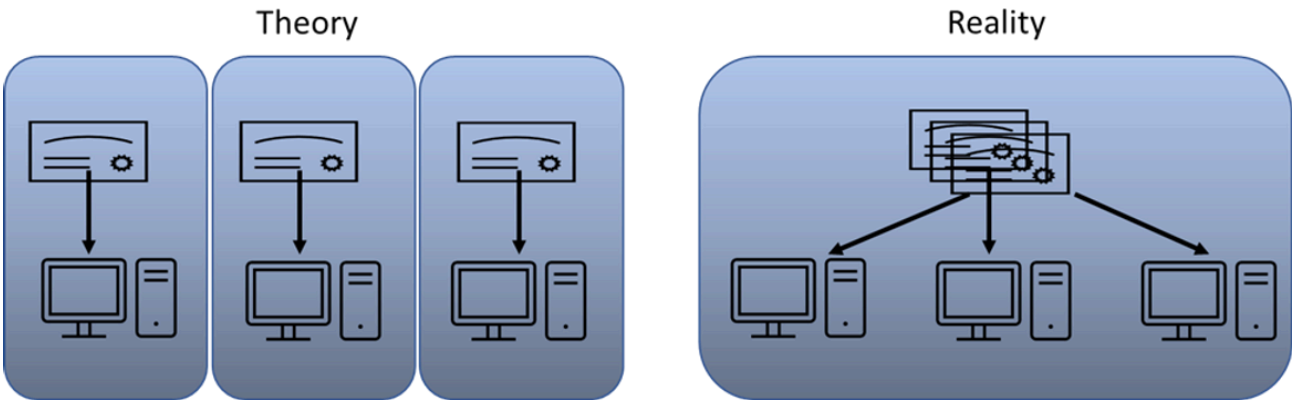
Despite these recommendations, Trimarc continues to find an SCCM push account in the Domain Administrators group in approximately 20% of Active Directory Security Assessments (ADSAs). By design, these accounts require local administrator rights across multiple endpoints. Even when spread across several accounts, these credentials are targeted by attackers as they are an ideal candidate to conduct ransomware attacks or move laterally in an environment.

Theory vs. Reality

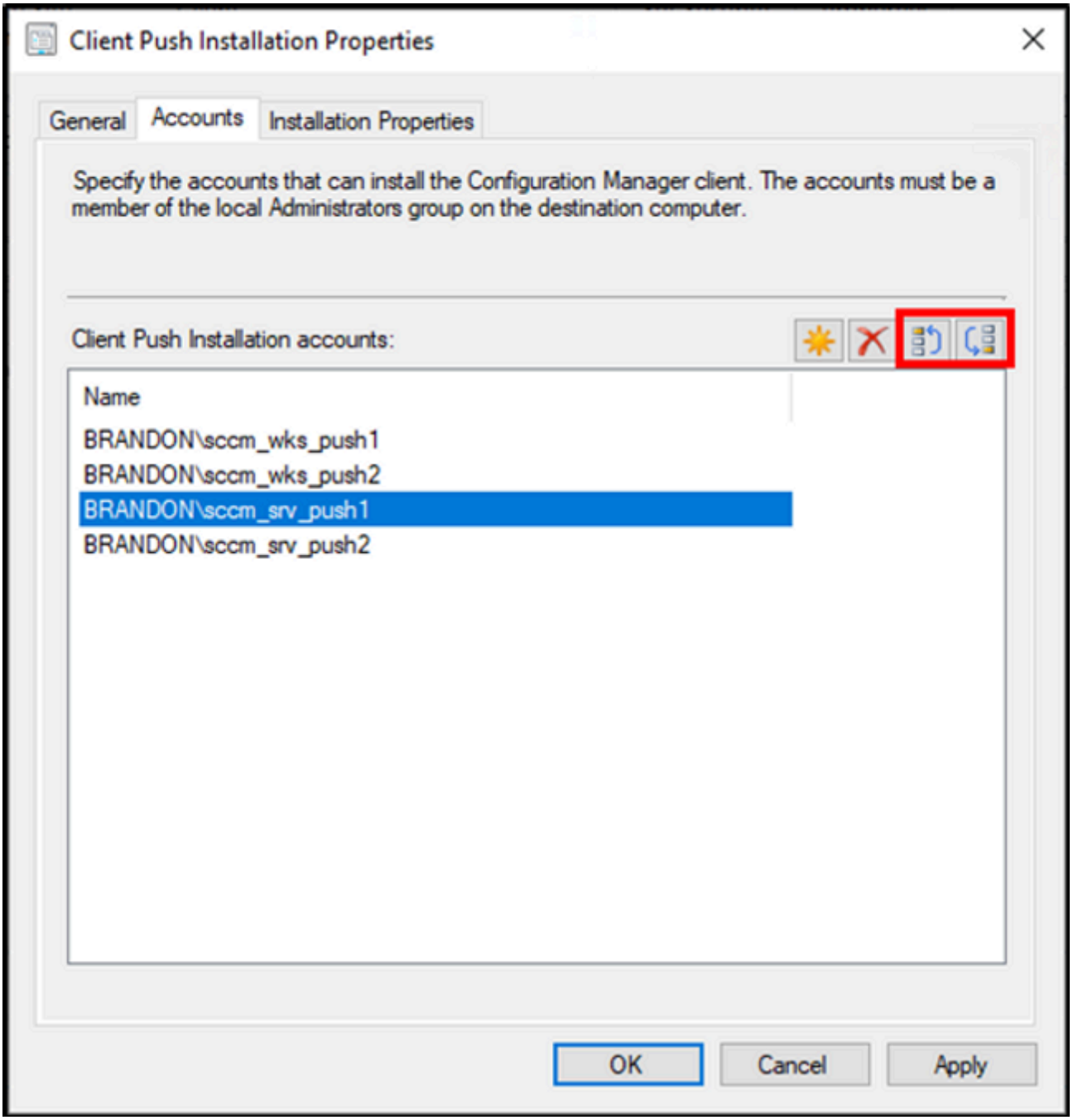
The risk associated with the client push account in the Domain Admins group should be clear. In general, the Domain Admins group membership should be restricted and heavily scrutinized. If an attacker were to retrieve these credentials, the entire domain (and AD forest) would be immediately compromised.

When configured per Microsoft's recommendation, only one push account should be granted elevated permissions on any given endpoint. The theory inferred here is that there is a one-to-one relationship between account and endpoint. An administrator can use multiple push accounts and configures each account to be used on a group of endpoints.

In reality, SCCM linearly traverses though each configured push account during client install. It will attempt to authenticate against the client with the first account. If initial authentication fails, SCCM will try the next configured account. This process repeats until authentication is successful or the list of configured accounts is exhausted.



When configuring the client push accounts, an administrator can determine the order in which this authentication will occur but cannot specify which accounts are used on which endpoints. This linear approach behaves much more like credential spraying, broadcasting all push account credentials throughout the network.



When authentication occurs, the protocol being used on the network is important to note. The lower the protocol security, the easier this vulnerability is to exploit. Microsoft supports multiple authentication protocols. NTLM and Kerberos are the most common.

NTLM

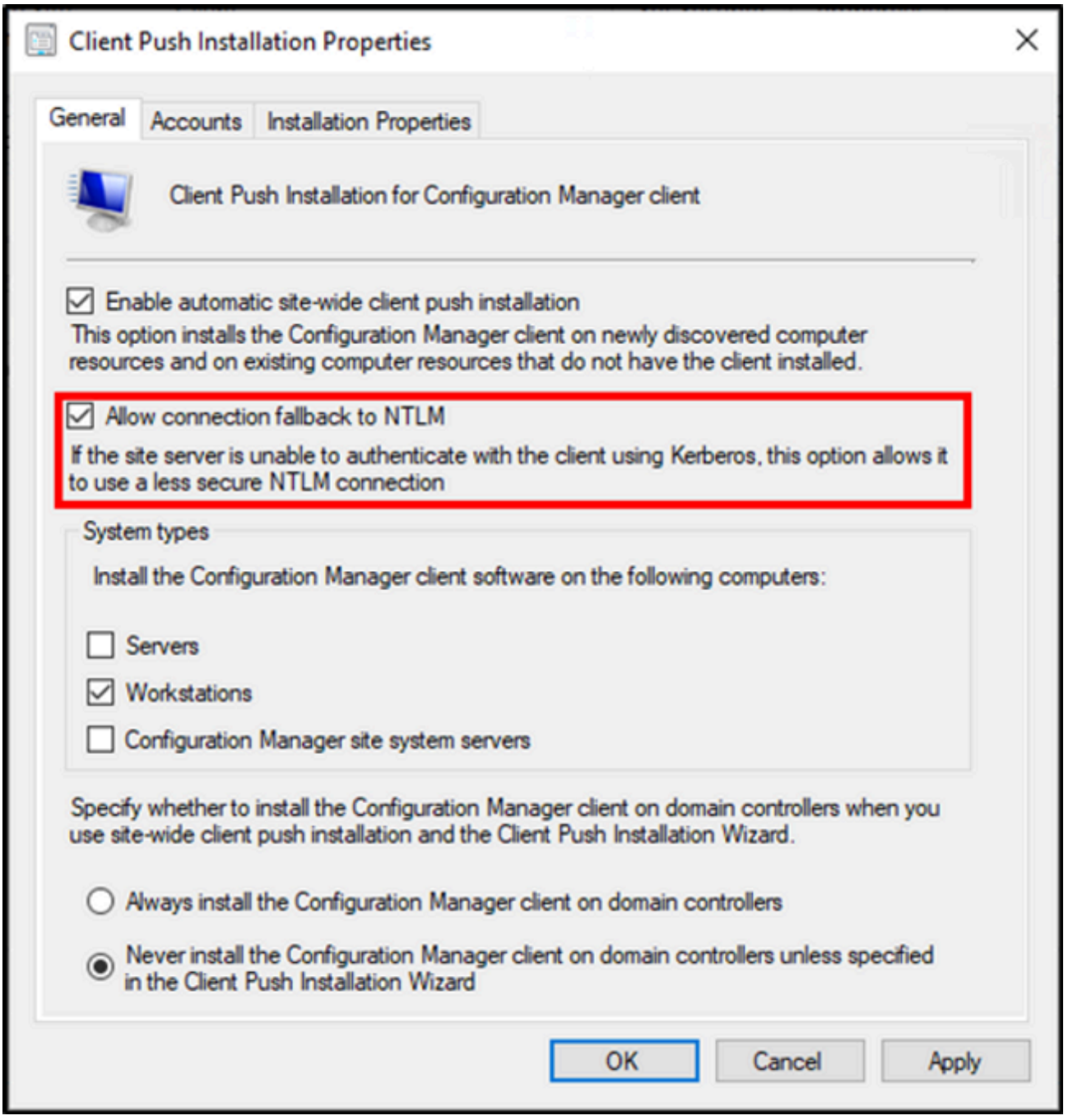
NTLM is an authentication protocol developed by Microsoft. This article uses the term NTLM interchangeably with Net-NTLMv1 and Net-NTLMv2. The v2 protocol is newer, and more secure than v1.

The protocol being used on your network is controlled via the group policy Security Options. In many situations, the Kerberos protocol has replaced NTLM and is much more secure.

Both NTLM version 1 and 2 utilize a hashed password for authentication. If this hash is captured, it can be cracked offline. Depending on the length, complexity, and version of the password hash, it could be cracked in a matter of seconds. Hashes are also susceptible to NTLM relay attacks. Relay attacks do not need to crack the password but instead forward the authentication around the network.

For more information on NTLM, Kerberos, and NTLM relay attacks, see these links from CrowdStrike and Qomplx. Trimarc's June 2022 webcast also covers NTLM & Kerberos relay attacks.

By default, SCCM still allows the authentication of client push accounts to fallback to use NTLM ("allow connection fallback to NTLM" is checked, as shown in the graphic below).



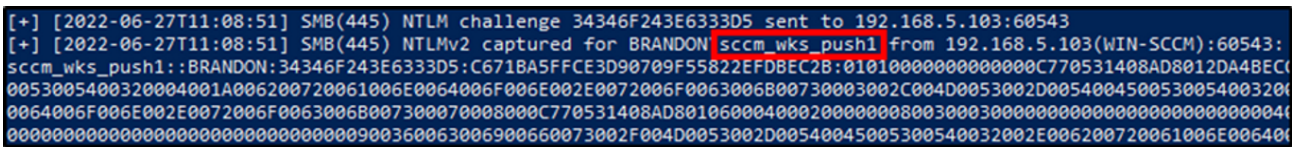
Putting it together: Attacking SCCM Push Accounts

If an attacker can gain control of an endpoint, they could remove all local administrators from the compromised machine. This ensures that every configured client push account would attempt authentication. Depending on the environment's NTLM settings and the attacker's methods, the hashes for all accounts would be sent over the network. Although each account itself has had its permissions reduced, the compromise of all push accounts at once puts an attacker one step from Domain Admin.

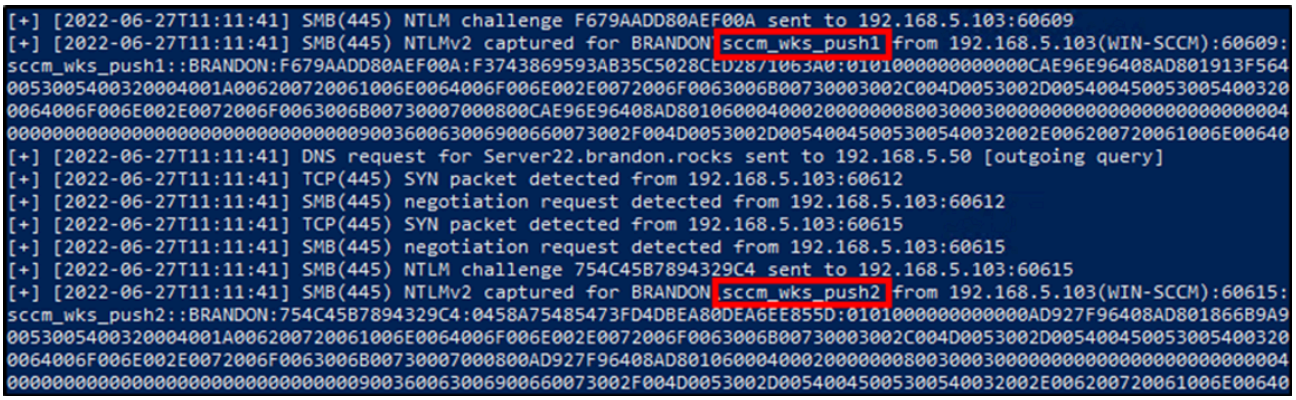
There is further concern if the same SCCM server is configured to manage both workstations and servers. This could mean that compromising one workstation would result in giving an attacker the hashed admin credentials for all servers in the environment.

Demonstration

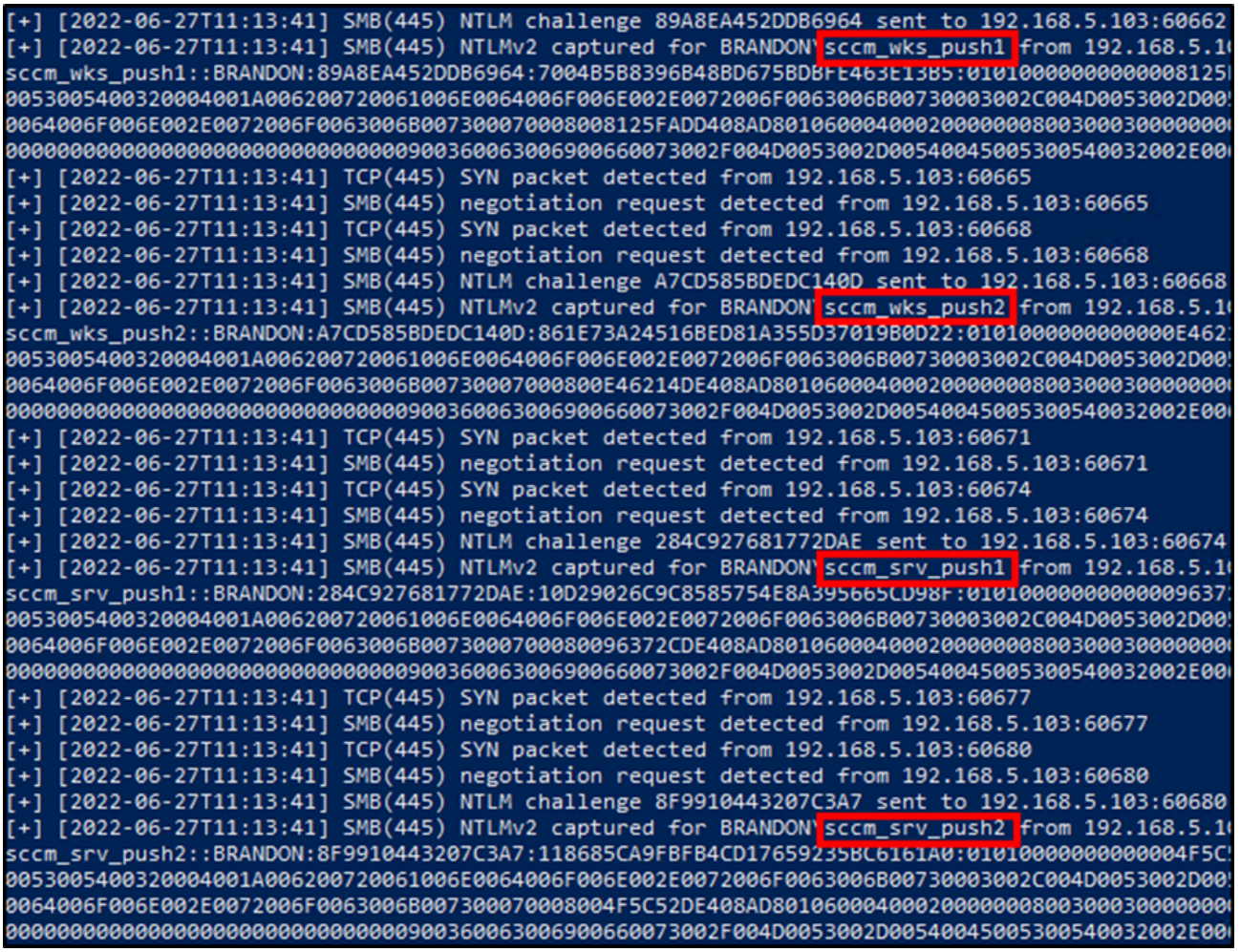
Below are examples of captured traffic in different scenarios. When the first configured client push account successfully authenticates, only the first hash is sent.



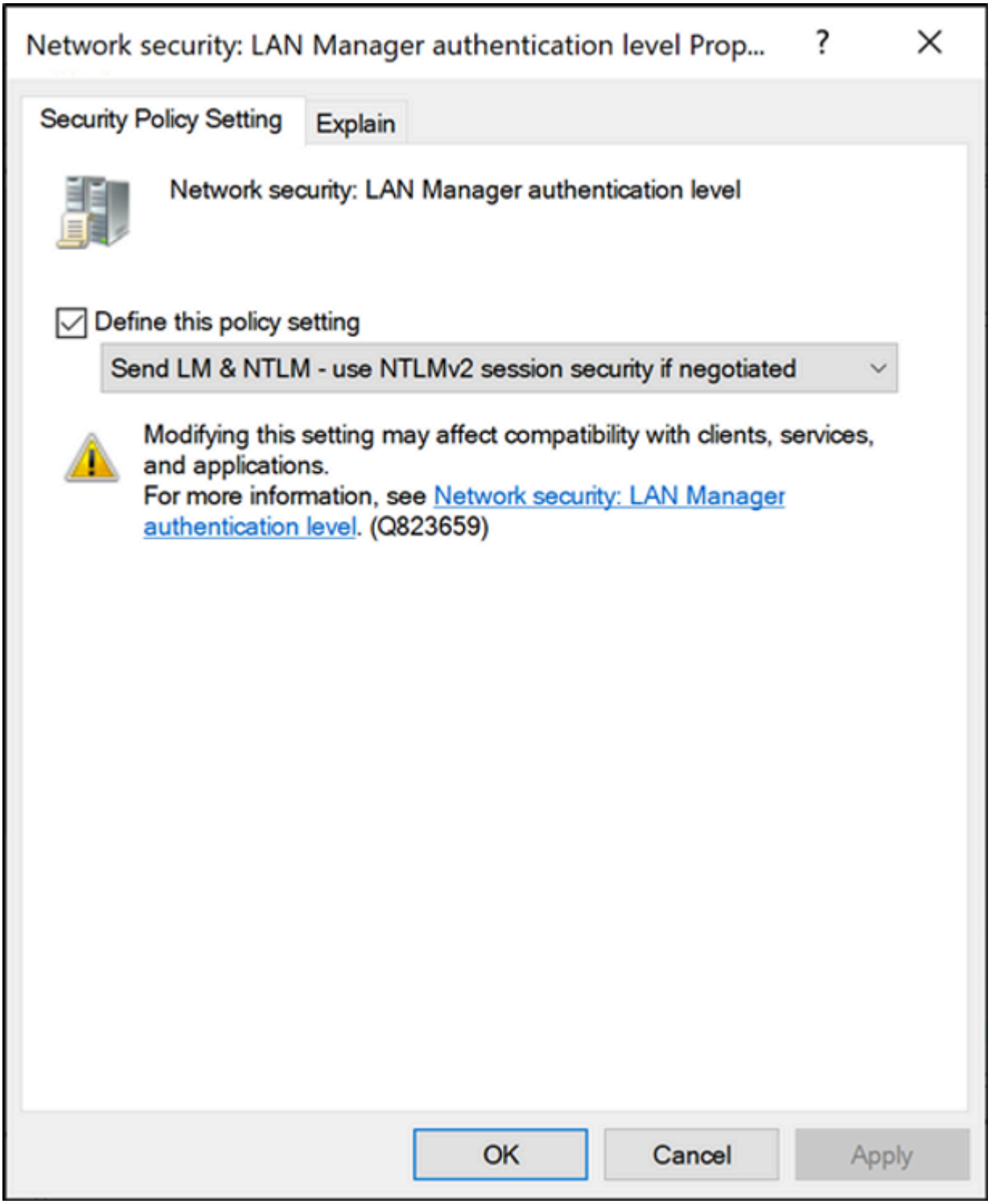
When the second configured client push account successfully authenticates, the first and second hash are sent.



Alternatively, if the attacker restricts the local Administrators group on the endpoint, no authentication will succeed and all hashes for configured push accounts will be sent.



The above hashes are all NTLMv2, but if the environment is configured to send NTLMv1, those hashes will be sent instead. NTLMv1 hashes are much shorter and much easier to crack.




```
[+] [2022-06-27T11:18:11] SMB(445) NTLM challenge 361DBDF367333A55 sent to 192.168.5.103:60733
[+] [2022-06-27T11:18:11] SMB(445) NTLMv1 captured for BRANDON\sccm_wks_push1 from 192.168.5.103(WIN-SCCM):60733:
sccm_wks_push1::BRANDON:FD22742850E283110000000000000000000000000000000:F71E38426BE3533FEF7E057289D81956E0C0C4A7E9BCC6F9:361DBDF367333A55
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60736
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60736
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60739
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60739
[+] [2022-06-27T11:18:11] SMB(445) NTLM challenge 1085082577ACAC21 sent to 192.168.5.103:60739
[+] [2022-06-27T11:18:11] SMB(445) NTLMv1 captured for BRANDON\sccm_wks_push2 from 192.168.5.103(WIN-SCCM):60739:
sccm_wks_push2::BRANDON:F6D9B5091A05114400000000000000000000000000000000:5185FFFEBA2612024B2D57888B6CA84EBB02AE0A78D64F23:1085082577ACAC21
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60742
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60742
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60745
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60745
[+] [2022-06-27T11:18:11] SMB(445) NTLM challenge E208AC504CCB914B sent to 192.168.5.103:60745
[+] [2022-06-27T11:18:11] SMB(445) NTLMv1 captured for BRANDON\sccm_srv_push1 from 192.168.5.103(WIN-SCCM):60745:
sccm_srv_push1::BRANDON:A3977B3313FCFA360000000000000000000000000000000:1FCB538300125BD48FC37AC58690A6D5D0A6E5A31340F991:E208AC504CCB914B
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60750
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60750
[+] [2022-06-27T11:18:11] TCP(445) SYN packet detected from 192.168.5.103:60753
[+] [2022-06-27T11:18:11] SMB(445) negotiation request detected from 192.168.5.103:60753
[+] [2022-06-27T11:18:11] SMB(445) NTLM challenge 3384A548F9C83B2C sent to 192.168.5.103:60753
[+] [2022-06-27T11:18:11] SMB(445) NTLMv1 captured for BRANDON\sccm_srv_push2 from 192.168.5.103(WIN-SCCM):60753:
sccm_srv_push2::BRANDON:DCE0CEE2336148DC0000000000000000000000000000000:06B105526A24C3175C2245FE27B3988E5C7ECE438B2ABC49:3384A548F9C83B2C
```

Conclusion

The client push installation design introduces flaws in security. With little effort, an attacker may be able to retrieve the hashed credentials for all configured SCCM push accounts. Because these accounts are granted local administrative rights across multiple systems, they can be used for lateral movement across a network or utilized in a ransomware attack that could cripple infrastructure.

Trimarc recommends the following best practices to help mitigate against this vulnerability.

1. Use multiple SCCM push accounts. Despite these findings, the use of multiple push accounts is still preferred over the use of a single push account for all endpoints. Use group policy or another endpoint management solution to configure one push account to each sub-group of assets.

2. Use long and complex passwords for all push accounts. Trimarc recommends passwords that are at least 25 characters long and highly complex. Note that a long and complex password only protects against offline password cracking since a credential hash can be used in other attacks regardless of complexity.

3. Trimarc typically suggests that service account passwords are changed every 12 months and whenever a member of the admin team leaves the organization. However, due to the nature of how SCCM push accounts work, it is instead recommended that the accounts are completely replaced on the same schedule. The old accounts should remain in place until the new accounts have completed replication in the environment.

4. Lock down client push accounts by denying local logon and marking them as “account is sensitive and cannot be delegated”.

5. Do not use the client push installation method for Domain Controllers or sensitive servers/workstations. Push accounts should not be added to the local administrator’s group on these systems. Manual installation of the client is preferred. Ideally, critical assets should not be managed by the same SCCM at all (or leverage a separate system entirely dedicated to “Tier 0” assets).

6. Evaluate the use of NTLM across the enterprise. At a minimum, the authentication level for Domain Controllers should be set to “Send NTLMv2 response only\refuse LM & NTLM”, and efforts should be made toward fully eliminating NTLM traffic. This process may prove incredibly difficult – especially in environments with legacy applications and large numbers of non-Windows devices. Enable NTLM auditing to determine NTLM use in the environment as described in Trimarc’s June 2022 webcast.

7. Starting in version 1806, Microsoft implemented the checkbox to “allow connection fallback to NTLM”. They recommend unchecking this setting to enforce Kerberos authentication. Note that clients must be in a trusted Active Directory to use this feature. Careful testing may be required to ensure there is no service disruption when disabling this setting.

In part 2 of this blog series, the setting for NTLM fallback is scrutinized. More attack methods will be explored that demonstrate the ability for an attacker to fully bypass this setting. **Due to these findings, continued use of the client push installation method is not recommended, and should not be used at all.**

Resources:

- NTLM restriction and auditing: https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-restrict-ntlm-outgoing-ntlm-traffic-to-remote-servers
- NTLM authentication levels: https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/network-security-lan-manager-authentication-level
- Tool used for hash dumps: https://github.com/Kevin-Robertson/Inveigh
- Security guidance for clients: https://docs.microsoft.com/en-us/mem/configmgr/core/clients/deploy/plan/security-and-privacy-for-clients
- Client installation methods: https://docs.microsoft.com/en-us/mem/configmgr/core/clients/deploy/plan/client-installation-methods



Trimarc Security Consultant with 15 years of experience administering and securing Active Directory and Windows environments.

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the enterprise. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of critical technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

How to contact Trimarc